UNIVERSITÀ DEGLI STUDI DI NAPOLI
FEDERICO II

Appunti di
Computer Forensic
Anno 2021

Valentino Bocchetti

Contents

1 Introduzione al corso **3**

1.1 Contatti 3

1.2 Esame 3

2 Lezione del 08-03 - Introduzione al corso **3**

2.1 Computer Forensics 3

2.2 Suddivisione della Digital Forensics 3

2.3 Campo di azione 4

2.4 L'ecosistema del Cybercrime 4

2.5 Sistema del Cybercrime 4

2.6 Metodologie 4

3 Lezione del 10-03 - Procedimento civile e penale **5**

3.1 Il procedimento penale e civile 5

3.2 Procedimento penale 5

3.3 Procedimento civile 7

4 Lezione del 15-03 - Gli attori del procedimento penale **7**

4.1 Struttura organizzativa 7

4.2 Organizzazione della procura 8

4.3 Pubblico Ministero (PM) 8

4.4 Polizia giudiziaria 8

4.5 La persona offesa 8

4.6 Esposto, Denuncia e Querela 8

4.6.1 Esposto . . . 8
4.6.2 Denuncia . . . 8
4.6.3 Querela . . . 8
4.7 Indagato e imputato . . . 9
4.7.1 Indagato . . . 9
4.7.2 Imputato . . . 9
4.7.3 Entrambi . . . 9
4.8 Avvocato . . . 9
4.9 Lato giudicante . . . 9
4.9.1 GIP (Giudice dell'indagine preliminare) . . . 9
4.9.2 GUP (Giudice dell'Udienza Preliminare) . . . 9
4.9.3 Giudice del dibattimento . . . 9
4.10 Computer Forenser . . . 10
4.10.1 Perito . . . 10

5 Lezione del 17-03 - Genesi del diritto informatico 10

5.1 Reato . . . 10
5.1.1 Reato informatico . . . 10
5.1.2 Consiglio di Europa (2001) . . . 11
5.2 Ransomware . . . 11

6 Lezione del 24-03 - Identificazione e Raccolta 11

6.1 Identificazione . . . 11
6.2 Preview . . . 11
6.2.1 Preview DEAD . . . 11

6.2.2 Preview LIVE . . . 11
6.2.3 Cambiamento di stato del dispositivo . . . 12
6.3 Raccolta . . . 12
6.3.1 Catena di custodia . . . 12
6.3.2 Sequestro fisico . . . 13
6.3.3 Sequestro logico . . . 13
6.4 Copia forense . . . 13
6.4.1 Acquisizione fisica . . . 14
6.4.2 Strumenti . . . 14

7 Lezione del 29-03 - Fasi del trattamento (validazione e preservazione) 14

7.1 Hash . . . 14
7.2 Validazione . . . 14
7.3 Preservazione . . . 14
7.4 File LOG . . . 14

8 Lezione del 31-03 - Raccolta e Validazione - Disk Image e Tool 15

8.1 Disk image (Fine anni 60) . . . 15
8.2 Formato `DD/RAW` . . . 15
8.3 Expert witness Disk Image Format (EWF) . . . 15
8.4 Encase E01 Bitstream . . . 16
8.5 Encase LO1 Logicale (famiglia EWF) . . . 16
8.6 Advanced Forensics Format (`AFF/AFF4`) . . . 16
8.7 Tool di acquisizione . . . 17
8.7.1 Guymanager . . . 17

8.7.2 FTK Imager 17

1 Introduzione al corso

1.1 Contatti

N° Telefono	Email
081-19576037 (fax) 335-5456550	lorenzo.laurato@ssrilab.com info@ssrilab.com

1.2 Esame

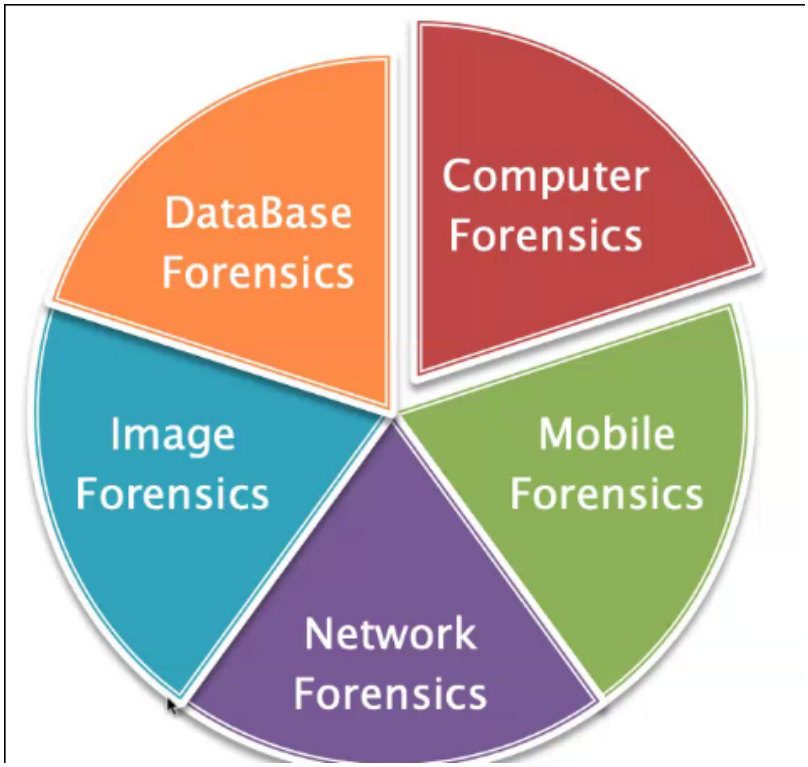
Esame scritto (risposta multipla) + orale

2 Lezione del 08-03 - Introduzione al corso

2.1 Computer Forensics

È l'insieme di metodologie scientificamente provate finalizzate alla ricostruzione di eventi ai fini probatori che coinvolgono direttamente o indirettamente un supporto digitale. Il problema della Computer Forensics è il trattamento dei dati

2.2 Suddivisione della Digital Forensics



2.3 Campo di azione

Il campo di azione di un digital forenser:

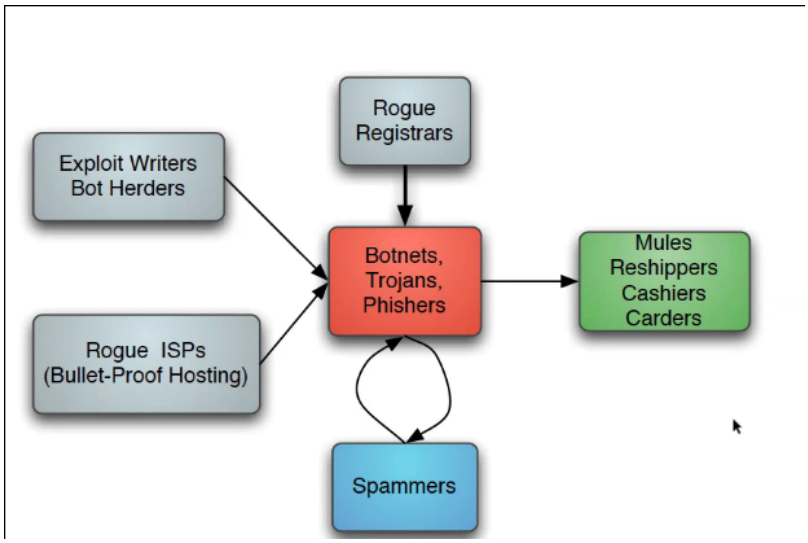
- Consulente tecnico;
- Forze dell'ordine;
- Cyber security office.

2.4 L'ecosistema del Cybercrime

Gli attacchi informatici sono implementati in varie forme diverse. La loro profittabilità dipende dal sistema che subisce l'attacco (*es* trojan, malware, etc. . .)

Esiste un mercato sulle vulnerabilità dei sistemi. Da ciò ne consegue l'interesse nella distribuzione di malware

2.5 Sistema del Cybercrime



2.6 Metodologie

- Identificazione → individuare i dispositivi che possono contenere dati rilevanti;
- Raccolta, Validazione, Preservazione → **copia forense** (copia di dati certificati tale che sia identica al dato originale);
- Analisi → entrare nel file system dei vari pc;
- Interpretazione;
- Documentazione, Presentazione → **catena di custodia**;

3 Lezione del 10-03 - Procedimento civile e penale

3.1 Il procedimento penale e civile

Area di attività del computer forenser

Area	Percentuale
Penale	48 %
Civile	20 %
Aziende	20 %
Amministrativo	7 %
Investigazioni private	5 %

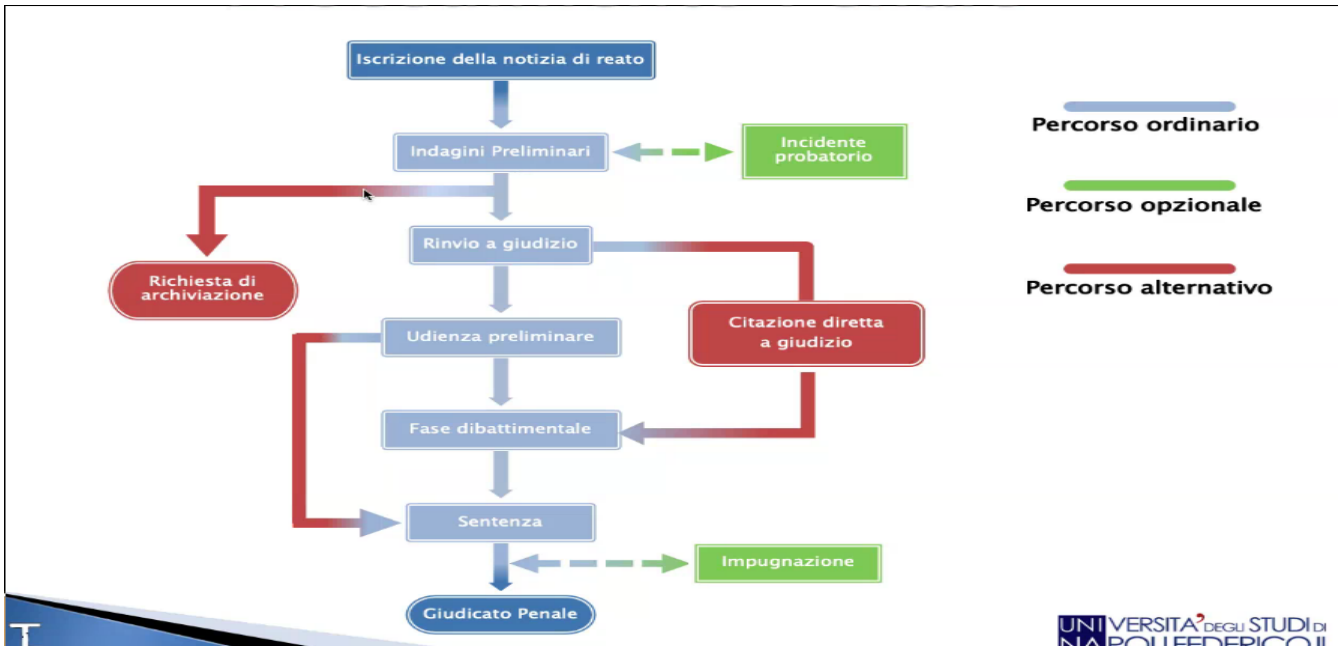
3.2 Procedimento penale

Procura della repubblica → il pubblico ministero gestisce le indagini ed ha il potere di esercitare l'azione penale.

Il tribunale → il giudice valuta le tesi accusatorie e difensive (condanna e assolve).

All'interno della procura ci sono i pubblici ministeri (lo scopo è indagare).

All'interno del tribunale ci sono i giudici.



Fase iniziale

Si svolgono le indagini ritenute necessarie alla verifica dell'attendibilità della notizia di reato (ricerca di prove). Si eseguono quindi le indagini preliminari, durante le quali si può fare uso di due strumenti giuridici:

- Perquisizione;
- Sequestro probatorio;

Entrambe atte alla conferma delle ipotesi iniziali di reato. Ne segue quindi una serie (opzionale) di **accertamenti tecnici** (richiesta di tecnici esterni).

Presente un tipo particolare di accertamento, detto **accertamento tecnico irripetibile** (provoca alterazione delle prove) → in questo caso si ha l'obbligo di avvisare entrambi le parti (indagato, parte offesa e relativi difernsori)

Misure cautelari

Sono misure emesse dal giudice atte alla limitazioni di `beni/cose` (misure reali) o limitazioni alla persona (misure personali)

Incidente probatorio

Ha lo scopo di anticipare l'acquisizione e la formazione di una prova durante le indagini preliminari

Richiesta di archiviazione

Interessa entrambe le parti e le motivazioni possibili possono essere:

- Gli elementi raccolti non sono sufficienti a sostenere l'accusa;
- L'autore del reato è rimasto ignoto;
- Il reato è estinto;
- Il fatto non è previsto dalla legge come reato;
- Il fatto è particolarmente tenue;
- La parte offesa presenta richiesta motivata di archiviazione.

Rinvio a giudizio

Avviso dell'indagato della conclusione delle indagini preliminari e informazioni sul capo di accusa

Dibattimento

Fase centrale del processo penale in cui si procede alla raccolta e acquisizione delle prove nel rispetto del contraddittorio delle parti:

- Prove documentate;
- Esame testimoniale;
- Perizia.

Sentenza

Fase conclusiva del processo penale, che può avere due risvolti:

- Proscioglimento
  - Sentenza di non doversi procedere;
  - Sentenza di assoluzione;
- Condanna;

3.3 Procedimento civile

Differenza sostanziale rispetto al procedimento penale è l'assenza nel procedimento civile della struttura della Procura (avviene tutto nel Tribunale).

4 Lezione del 15-03 - Gli attori del procedimento penale

4.1 Struttura organizzativa

- Uffici magistratura inquirente
  - Procure della repubblica `c/o` i tribunali ordinari, per i minorenni, militari;
  - Procure Generali `c/o` le Corti d'Appello;
  - Procure Generali `c/o` la Suprema corte di Cassazione;
- Uffici magistratura giudicante
  - Tribunali Ordinari;
  - Tribunali per i Minorenni;
  - Tribunali Militari;
  - Corte di Appello;
  - Suprema Corte di Cassazione.

4.2 Organizzazione della procura

Gli uffici di procura sono organizzati in gruppi di lavoro specializzati nella trattazione di specifici reati.

4.3 Pubblico Ministero (PM)

Organo dell'amministrazione giudiziaria dello stato designato per garantire il rispetto della legge e per valutare le azioni penali di un individuo. È titolare delle indagini ed ha il compito di esercitare l'azione penale.

Rappresenta la pubblica accusa.

4.4 Polizia giudiziaria

Forze di polizia che collaborano con il PM nelle attività di indagine e che dipendono direttamente dalla Procura.

Svolge determinate attività sia in modo autonomo, sia su delega dell'autorità giudiziaria:

- Attività informativa;
- Attività investigativa;
- Attività di prevenzione;
- Attività assicurativa

Ha una funzione repressiva.

4.5 La persona offesa

È il soggeto titolare del bene giuridico leso dall'autore di un reato.

4.6 Esposto, Denuncia e Querela

4.6.1 Esposto

Segnalazione all'Autorità Giudiziaria di un fatto allo scopo di far valutare se ricorre un'ipotesi di reato.

4.6.2 Denuncia

Atto con il quale si informa l'Autorità Giudiziaria di una notizia di reato perseguibile d'ufficio.

4.6.3 Querela

Dichiarazionme della persona offesa con la quale si esprime la volontà di punire il colpevole per un reato subito, non perseguibile d'ufficio. Può essere ritirata (*rimessa*) se non si tratta di reati sessuali ai danni di minori (*irrevocabile*).

4.7 Indagato e imputato

4.7.1 Indagato

La persona nei cui confronti vengono svolte indagini a seguito dell'iscrizione di un fatto a lui addebitato nel registro delle notizie di reato.

4.7.2 Imputato

La persona indagata nei confronti della quale è stta esercitata l'azione penale (rinvio a giudizio).

4.7.3 Entrambi

Hanno l'obbligo di farsi assistere da un difensore.

4.8 Avvocato

- Ruolo di assistenza;
- Ruolo di rappresentanza;

4.9 Lato giudicante

4.9.1 GIP (Giudice dell'indagine preliminare)

Funzione di garanzia dell'indagato nella fase delle indagini preliminari.

4.9.2 GUP (Giudice dell'Udienza Preliminare)

Interviene dopo l'esercizio dell'azione penale;

Giudica la richiesta di rinvio a giudizio (celebrazione del processo)

Il giudice potrà:

- Emettere decreto di rinvio a giudizio;
- Emettere sentenza di non luogo a procedere.

4.9.3 Giudice del dibattimento

Presiede a tutta la fase dibattimentale e alle relative udienze. Può essere in composizione Monocratica o Collegiale.

Per i reati più efferati è prevista una distinta composizione definita Corte d'Assise dove è presente anche la Giuria Popolare.

Emette la sentenza

4.10 Computer Forenser

Nel caso in cui siano richieste competenze tecniche può essere nominato dall'autorità giudiziaria un *consulente tecnico*.

Il CF deve impiegare metodi e strumenti che garantiscono l'inalterabilità della prova (sempre che l'ogetto in esame non porti ad un alterazione → accertamento irripetibile (c'è l'obbligo di avvisare tutte le parti))

4.10.1 Perito

Caso in cui il CF venga nominato dal Giudice.

5 Lezione del 17-03 - Genesi del diritto informatico

5.1 Reato

È quell'illecita azione o omissione teso a ledere un bene tutelato giuridicamente e a cui viene corrisposta una pena. Può essere:

- Doloso → consapevolezza e volontà di commettere un reato;
- Preterintenzionale → le conseguenze sono più gravi di quanto voluto;
- Colposo → manca la volontà di determinare un qualsiasi evento costituente reato, ma l'evento si verifica ugualmente

5.1.1 Reato informatico

Illecito che richiede conoscenze di informatica per la sua realizzazione.

Comporta il coinvolgimento di un qualunque tipo di elaboratore.

Illecito nel quale il PC interviene come strumento o come oggetto.

Ciò comporta a meglio definire il reato informatico → si rinuncia a darne una definizione precisa.

1. Lista minima e facoltativa Minima → condotte criminose che gli stati devono reprimere mediante una sanzione penale.

   Facoltativa → varia in base ai singoli paesi (condotte "solo eventualmente" da incriminare)
2. Frode informatica La frode informatica (altresì detta frode elettronica) in generale consiste nel penetrare attraverso un PC all'interno di altri PC o server che gestiscono servizi con lo scopo di rubare dati o ottenere tali servizi gratuitamente, oppure, sempre utilizzando il server al quale si è avuto accesso, clonare account di inconsapevoli utilizzatori del servizio.

5.1.2 Consiglio di Europa (2001)

Primo trattato internazionale sulle infrazioni penali commesse via internet e su altre reti informatiche (L'italia si adegua nel 2008).

5.2 Ransomware

I dati presenti sul PC sono cifrati cancellando perennemente gli originali e proteggendoli con una chiave di cifratura che l'utente non conosce e che quindi non potrà utilizzare per ripristinare i propri documenti.

Scopo → estersione (pagamento in bitcoin).

6 Lezione del 24-03 - Identificazione e Raccolta

6.1 Identificazione

Ricercare la fonte di prova che può dare una svolta alle indagini: `la prima fase è volta a individuare dove un dato è conservato`.

6.2 Preview

Consente di eseguire un'analisi di primo livello delle memorie dei dispositivi allo scopo di individuare possibili elementi di interesse investigativo.

Utilizzo di **write blocker** (`SW/HW` ad hoc). Rischio di alterazione dei contenuti con conseguente dispersione di una possibile prova.

6.2.1 Preview DEAD

Analisi eseguita con il SO spento. → uso di write block, con il quale è possibile non alterare il dispositivo da analizzare.

HW o SW (distro linux)

PRO	CONTRO
Permette di non alterare il dispositivo	Buona conoscenza del SO e dei software da analizzare
Consente di utilizzare diversi strumenti per analizzare la memoria del dispositivo	Non sempre praticabile (sistemi embedded)

6.2.2 Preview LIVE

Analisi eseguita impiegando il SO

PRO	CONTRO
Avere una visione dell'ambiente in cui opera l'utente	Alterazione del reperto
Veloce nell'analisi dei software installati	Strumenti adeguati al sistema

6.2.3 Cambiamento di stato del dispositivo

$$\text{Acceso} \rightarrow \text{Spento}$$

$$\text{Spento} \rightarrow \text{Acceso}$$

Bisogna considerare le seguenti criticità_

- Cifratura;
- SW in esecuzione;
- Dump della RAM.

Per spegnere la il dispositivo che si vuole organizzare vanno eseguite una delle seguenti modalità:

- *unplug*
  - Potrebbe compromettere il funzionamento del SO (Server, RAID. . .);
- Eseguire lo spegnimento mediante il SO
  - vengono eseguite sul disco diverse operazioni.

6.3 Raccolta

Una volta identificati i dispositivi di possibile interesse investigativo si procede con il sequestro che può essere di 2 tipi:

- fisico (si prende fisicamente il supporto);
- logico (copia totale o parziale della memoria del dispositivo).

6.3.1 Catena di custodia

Uno o più documenti in cui devono essere riportati tutte le informazioni sul dispositivo che è stato sottoposto a seequestrato (fisico o logico). Contiene:

- Il luogo, data e operatore che ha reperito e collezionato la fonte di prova;
- Il luogo, data e operatore che ha esaminato la fonte di prova;
- Chi ha la responsabilità della custodia delle *digital evidences*;
- Metodo di conservazione del reperto;
- Eventuali trasperimenti di location dell'evidenza.

6.3.2 Sequestro fisico

Non sempre fattibile. È il caso di:

- Sistemi che non possono essere `fermati/spenti`;
- Sistemi distribuiti.

6.3.3 Sequestro logico

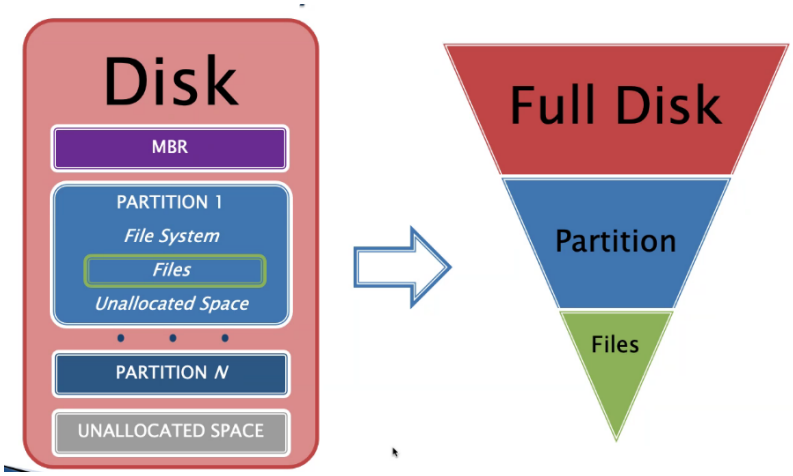
Duplicazione dei dati di *possibile* interesse investigativo (copia forense).

6.4 Copia forense

Garanzia di ripetibilità dei successivi accertamenti che verranno eseguiti sulla copia forense

Rispetto alla comune copia, questa risponde a:

- Validazione;
- Copia;
- Preservazione.



6.4.1 Acquisizione fisica

Copia *bit a bit* dell'intero supporto di memoria: dati e qualsiasi informazione sulla gestione dei dati (tabella partizioni, MBR, meta dati del file system). Due tipi di sistemi:

- Clonazione
  - ha come risultato un supporto pressochè a quello originale;
  - facilmente alterabile;
  - utilizzato solo in casi particolari (bisogna analizzare il supporto reinserendolo all'interno del proprio habitat)
- File Immagine
  - Rappresentazione del supporto originale sottoforma di file.

6.4.2 Strumenti

Di tipo o HW o SW

7 Lezione del 29-03 - Fasi del trattamento (validazione e preservazione)

7.1 Hash

L'algoritmo restituisce una stringa a lunghezza fissa di esadecimale apartire da un flusso di bit (dati) di dimensione qualsiasi. La stringa prodotta in output è univoca per ogni file e ne è un identificatore.

L'algoritmo non è invertibile, ossia non è possibile ricostruire il dato originale a partire dalla stringa che viene restituita in output

7.2 Validazione

Garantisce che la copia eseguita è identica al dato originale.

7.3 Preservazione

Garantisce che non vengano eseguite `modifiche/alterazioni` alla copia, in caso contrario il valore di hash sarà differente

7.4 File LOG

File descrittivo in cui sono presenti le informazioni sulla copia forense realizzata:

- Informazioni sullo strumento impiegato;

- Informazioni sul disco di origine;
- Informazioni dell'immagine forense;
- HASH.

8 Lezione del 31-03 - Raccolta e Validazione - Disk Image e Tool

8.1 Disk image (Fine anni 60)

Mondo aziendale → disaster recovery

Mondo user → duplicazione supporti ottici (backup, facilitare la masterizzazione, diffusione `SW/utility`)

Formato VDMK, VDI, VHD, DMG.

8.2 Formato `DD/RAW`

Formato semplice → container dello stream.

Problematiche:

- Non conserva metadati dell'evidence;
- Non conserva hash calcolati;
- Non esegue compressione;
- Non può contenere più di un `file/stream`.

8.3 Expert witness Disk Image Format (EWF)

Presenta:

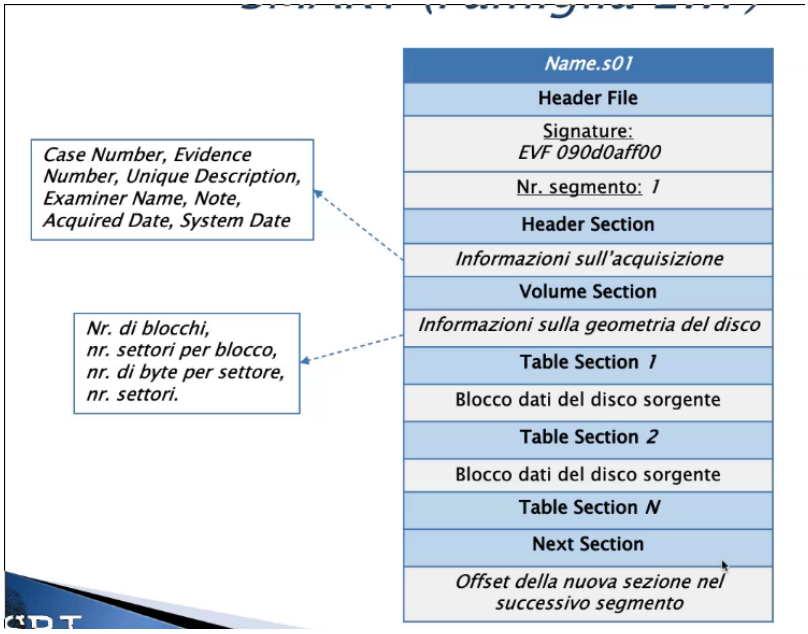
- File immagine composto in sezioni;
- compressione → algoritmo deflate;
- Segmentazione dell'immagine.

Lo scopo è quello di avere un accesso veloce ad una parte dell'immagine.

Ogni segmento presenta:

- Header file → *Signature e nr. di segmento*;
- Una o più sezioni
    1. *header section*;

2. *volume section*;
3. *table section*;
4. `next/done` *section*.



8.4 Encase E01 Bitstream

- Basato sul formato SMART;
- Segmentazione dell'immagine;
- Tre livelli di compressione
  - *no*;
  - *good*;
  - *best*.
- Impiega nr. 13 sezioni (+9 al formato SMART).

8.5 Encase LO1 Logicale (famiglia EWF)

- Acquisizione di file logici;
- Segmentazione dell'immagine;
- Impiega nr. 15 sezioni (+2 al formato E01).

8.6 Advanced Forensics Format (`AFF/AFF4`)

- Formato open ed estensibile;

- Creato prima dell'implementazione open source di libewf (2006);
- Ogni disco viene separato in 2 layer
  - disk-rapresentation layer (metadato);
  - data-storage layer (dato).

8.7 Tool di acquisizione

8.7.1 Guymanager

- Sviluppo da Guy Voncker;
- Licenza → Free OpenSource;
- Piattaforma → Linux;
- Basato sulla libreria libewf (clone + disk image);

Permette la full disk image soltanto

8.7.2 FTK Imager

- Prodotto dalla AcceData;
- Licenza → Freeware;
- Piattaforma → win (*lite* e *install version*)